

Deployment Assist Tool (DAT)

Automated DevSecOps Scan Report & AI Remediation Manifest

Generated: 6/3/2026, 12:41:20 AM

✖

Quality Gate FAILED — deployment blocked

Blocked by 4 HIGH finding(s) at the configured failOn severities (CRITICAL, HIGH).

34/100

READINESS SCORE

0

CRITICAL

4

HIGH

1

MEDIUM

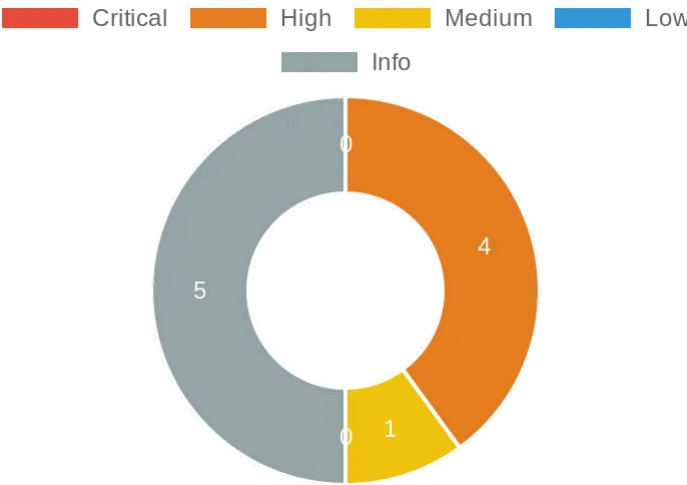
0

LOW

How this score was calculated

34/100 — Blocked — critical/high findings present. (100 – $\sum$ (weight × log₂(1 + count)) per severity, clamped to 0–100)

Severity	Count	Weight	Penalty applied
CRITICAL	0	60	–0
HIGH	4	25	–58
MEDIUM	1	8	–8
LOW	0	2	–0
Total penalty			–66



How to read this report

How DAT works

1. Detect the project ecosystem(s) and select the applicable scanners.
2. Preflight: verify the app has the inputs needed for a meaningful scan (POC→Enterprise readiness).
3. Run security/quality/test scanners AND per-component evaluators (fail-safe, robustness, coherence).
4. Deduplicate findings, compute the readiness score, and evaluate the Quality Gate.
5. Emit human reports (console / HTML / PDF) and a machine fix-manifest for coding agents (Claude Code).

The Quality Gate

The Quality Gate is the deploy decision. It FAILS when the scan finds any issue at a severity listed in `failOn` (default: CRITICAL, HIGH), or when a scanner errored. Otherwise it PASSES. This is independent of the readiness score. This run blocks on: **CRITICAL, HIGH**.

What the severities mean

CRITICAL	An exploitable flaw or breaking defect that puts production at immediate risk.	Must be fixed before deploying.
HIGH	A serious security or correctness issue likely to cause harm in production.	Fix before release; blocks the gate by default.
MEDIUM	A real weakness that increases risk but is not immediately exploitable.	Plan a fix soon; advisory by default.
LOW	A minor or cosmetic issue with limited impact.	Fix opportunistically.
INFO	Informational context, not a defect.	No action required.

What the finding categories mean

Security	A vulnerability an attacker could exploit.	Directly exposes the application or its data to attack.
Defect	The application behaves incorrectly (e.g. a failing test).	Broken logic reaches users and erodes trust.
Robustness	Missing resilience: no timeout, no error handling, no input validation.	The app fails unpredictably under load, bad input, or upstream outages.
Coherence	Components disagree (e.g. a UI call that an endpoint will reject).	Mismatches cause runtime failures that unit tests miss.
Fail-safe	A control lacks a safe default or handled failure path.	When something goes wrong, the app does the unsafe thing.
Best practice	Deviation from a hardening or quality convention.	Accumulated drift makes the system harder to secure and maintain.
Coverage gap	A check could not run (missing tool or input), so this area is unverified.	An unverified area is not the same as a safe one.

The readiness score

Range 0–100 (higher is healthier). Bands: **80–100** (green) — Healthy — minor issues only.; **50–79** (yellow) — Caution — address before the next deploy.; **0–49** (red) — Blocked — critical/high findings present.; Severity dominates volume (one CRITICAL outweighs many LOWs) and repeated findings of the same severity have diminishing impact. The score is a health indicator — the pass/fail decision is the Quality Gate, not the score.

Coverage gaps (checks that did not run)

These scanners were skipped, so the related risk areas are **unverified** (not necessarily safe):

- **SonarQube:** Required tool(s) not found on PATH: sonar-scanner
- **Qodo Cover-Agent:** Required tool(s) not found on PATH: cover-agent

- **Gitleaks (Secrets):** Required tool(s) not found on PATH: gitleaks

Detailed Findings & AI Remediation Data

Each finding shows its category and why it matters, plus a machine-readable remediation block for AI assistants (Claude Code, etc.).

Dockle Findings

INFO

DOCKLE-NO-IMAGE

Dockle

Description: Image 'project-image:latest' not found locally. Skipping Dockle scan.

```
// AI REMEDIATION MANIFEST
Target_File: Global/Dependency
Target_Line: N/A
Issue_Type: DOCKLE-NO-IMAGE
Severity: INFO
Category: n/a

Instruction: Fix the issue described below.
"Image 'project-image:latest' not found locally. Skipping Dockle scan."
```

OSV-Scanner Findings

HIGH

GHSA-4r6h-8v6p-xvw6

OSV-Scanner

Description: Package xlsx@0.18.5 is vulnerable: Prototype Pollution in sheetJS

Location: /Users/heisenberg/Projects/deployment_assist_tool/package-lock.json

```
// AI REMEDIATION MANIFEST
Target_File: /Users/heisenberg/Projects/deployment_assist_tool/package-lock.json
Target_Line: N/A
Issue_Type: GHSA-4r6h-8v6p-xvw6
Severity: HIGH
Category: n/a

Instruction: Fix the issue described below.
"Package xlsx@0.18.5 is vulnerable: Prototype Pollution in sheetJS"
```

HIGH

GHSA-5pgg-2g8v-p4x9

OSV-Scanner

Description: Package xlsx@0.18.5 is vulnerable: SheetJS Regular Expression Denial of Service (ReDoS)

Location: /Users/heisenberg/Projects/deployment_assist_tool/package-lock.json

```
// AI REMEDIATION MANIFEST
Target_File: /Users/heisenberg/Projects/deployment_assist_tool/package-lock.json
Target_Line: N/A
Issue_Type: GHSA-5pgg-2g8v-p4x9
Severity: HIGH
Category: n/a
```

```
Instruction: Fix the issue described below.
"Package xlsx@0.18.5 is vulnerable: SheetJS Regular Expression Denial of
Service (ReDoS)"
```

OWASP ZAP Findings

INFO

DAST-COVERAGE-GAP

OWASP ZAP

Description: No target URL was available for DAST scanning, so dynamic vulnerabilities (XSS, CSRF, SQLi, broken authorization) were NOT tested. Provide --url <target> (or ensure the ephemeral deployment succeeds) to enable active scanning.

```
// AI REMEDIATION MANIFEST
Target_File: Global/Dependency
Target_Line: N/A
Issue_Type: DAST-COVERAGE-GAP
Severity: INFO
Category: n/a
```

```
Instruction: Fix the issue described below.
"No target URL was available for DAST scanning, so dynamic
vulnerabilities (XSS, CSRF, SQLi, broken authorization) were NOT tested.
Provide --url <target> (or ensure the ephemeral deployment succeeds) to
enable active scanning."
```

k6 Load Test Findings

Description: No target URL was available for load testing, so performance and robustness under load were NOT measured. Provide --url to enable.

```
// AI REMEDIATION MANIFEST
Target_File: Global/Dependency
Target_Line: N/A
Issue_Type: LOAD-COVERAGE-GAP
Severity: INFO
Category: n/a
```

Instruction: Fix the issue described below.
"No target URL was available for load testing, so performance and robustness under load were NOT measured. Provide --url to enable."

Garak (LLM DAST) Findings

Description: No target URL provided for LLM DAST scanning. Use --url to enable.

```
// AI REMEDIATION MANIFEST
Target_File: Global/Dependency
Target_Line: N/A
Issue_Type: NO-URL
Severity: INFO
Category: n/a
```

Instruction: Fix the issue described below.
"No target URL provided for LLM DAST scanning. Use --url to enable."

Trivy (FS) Findings

HIGH**CVE-2023-30533**

Trivy

Description: xlsx (0.18.5) is vulnerable.**Location:** package-lock.json

```
// AI REMEDIATION MANIFEST
Target_File: package-lock.json
Target_Line: N/A
Issue_Type: CVE-2023-30533
Severity: HIGH
Category: n/a

Instruction: Fix the issue described below.
"xlsx (0.18.5) is vulnerable."

Suggested_Remedy: Update to 0.19.3
```

HIGH**CVE-2024-22363**

Trivy

Description: xlsx (0.18.5) is vulnerable.**Location:** package-lock.json

```
// AI REMEDIATION MANIFEST
Target_File: package-lock.json
Target_Line: N/A
Issue_Type: CVE-2024-22363
Severity: HIGH
Category: n/a

Instruction: Fix the issue described below.
"xlsx (0.18.5) is vulnerable."

Suggested_Remedy: Update to 0.20.2
```

Logic Tests Findings

Description: Logical test suite passed (command: `npm test`).

```
// AI REMEDIATION MANIFEST
Target_File: Global/Dependency
Target_Line: N/A
Issue_Type: LOGIC-TESTS-PASSED
Severity: INFO
Category: n/a

Instruction: Fix the issue described below.
"Logical test suite passed (command: `npm test`)."

```

Component Evaluator Findings

MEDIUM**COMP-APICALL-NO-ERROR-HANDLING**

Robustness · Component Evaluator

Why it matters: The app fails unpredictably under load, bad input, or upstream outages.

Description: State-changing API call POST `${url}/api/v2/import-scan/` has no error handling — a failed request fails silently or crashes the UI.

Location: `src/reporters/defectdojo.ts:23`

```
// AI REMEDIATION MANIFEST
Target_File: src/reporters/defectdojo.ts
Target_Line: 23
Issue_Type: COMP-APICALL-NO-ERROR-HANDLING
Severity: MEDIUM
Category: robustness

Instruction: Fix the issue described below.
"State-changing API call POST ${url}/api/v2/import-scan/ has no error
handling — a failed request fails silently or crashes the UI."

Suggested_Remedies: Wrap the call in try/catch (or add .catch) and surface
the failure to the user; never assume a mutating request succeeds.

```